COBRA7 | CHECKLIST

# قائمة فحص أمان تطبيقات الويب

9 مراحل من الاستطلاع لحد التقرير

قائمة مرجعية لفحص تطبيق ويب بتصريح. اطبعها وعلّم على اللي خلصته.

## 1) الاستطلاع والتحضير

- [ ] تصريح كتابي بالنطاق والوقت.
- [ ] تحديد الصفحات والـAPIs والـParameters.
- [ ] معرفة التقنيات المستخدمة (سيرفر، إطار عمل، قاعدة بيانات).

## 2) تسجيل الدخول

- [ ] حد لعدد محاولات الدخول الفاشلة.
- [ ] سياسة باسوورد معقولة (طول وليس تعقيد فقط).
- [ ] وجود MFA للحسابات الحساسة.
- [ ] استرجاع الباسوورد بتوكن مرة واحدة وله مدة انتهاء.
- [ ] رسالة خطأ موحدة لا تكشف إن كان المستخدم موجود.

## 3) الجلسات (Sessions)

- [ ] الكوكيز عليها Secure وHttpOnly وSameSite.
- [ ] تجديد معرّف الجلسة بعد تسجيل الدخول.
- [ ] إنهاء الجلسة فعليًا عند تسجيل الخروج.
- [ ] انتهاء الجلسة بعد فترة خمول.

## 4) الصلاحيات

- [ ] تجربة تغيير كل id في الطلبات (IDOR).
- [ ] الوصول لصفحات الأدمن بحساب عادي وبدون حساب.
- [ ] تجربة HTTP Methods مختلفة على نفس الرابط.
- [ ] التحقق من الصلاحية على السيرفر مش على الواجهة فقط.

## 5) المدخلات

- [ ] SQL Injection في كل Parameter.
- [ ] XSS (Reflected وStored وDOM).
- [ ] Command Injection وPath Traversal.
- [ ] رفع الملفات: نوع وحجم ومكان التخزين واسم الملف.
- [ ] Template Injection (SSTI) لو فيه قوالب.

## 6) منطق التطبيق

- [ ] تخطي خطوات (دفع أو تأكيد).
- [ ] قيم سالبة أو كبيرة جدًا.
- [ ] تكرار نفس الطلب في نفس اللحظة (Race Condition).
- [ ] استخدام كود خصم أكتر من مرة.

## 7) الـAPI

- [ ] مصادقة على كل Endpoint.
- [ ] حد لعدد الطلبات (Rate Limit).
- [ ] Mass Assignment: إرسال حقول زيادة.
- [ ] الرد مفيهوش بيانات أكتر من اللازم.

## 8) الإعدادات

- [ ] HTTPS مفعّل مع HSTS.
- [ ] Headers: CSP وX-Content-Type-Options وX-Frame-Options.
- [ ] رسائل الأخطاء مش بتكشف تفاصيل داخلية.
- [ ] ملفات حساسة مكشوفة (.env, .git, نسخ احتياطية).
- [ ] إعدادات CORS مش مفتوحة للكل.

## 9) التقرير

- [ ] كل ثغرة موثقة بخطوات وإثبات.
- [ ] تصنيف الخطورة والأثر.

- [ ] توصية واضحة للحل لكل ثغرة.

---

**تنبيه قانوني:** المحتوى ده للتعليم والعمل المصرّح بيه فقط. اختبار أو فحص أنظمة مش بتملكها من غير تصريح كتابي صريح مخالف للقانون.